CONFIDENTIAL SECURITY DOCUMENT

Cloud Security Configuration Assessment

Example Corp — AWS Production Account (123456789012)

AWS

Document Type	Cloud security configuration review (IAM, network, data, logging)
Cloud Provider	[FILL: AWS / Azure / GCP]
Accounts/Projects in Scope	[FILL: list account/subscription/project IDs]
Assessment Date	1 January 2030
Findings	[FILL: N (n Critical, n High, n Medium, n Low)]
Overall Risk	CRITICAL
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive security information and must not be shared outside authorised personnel responsible for remediation.

Scope of analysis: [FILL: One or two sentences, e.g. "a read-only configuration review via the cloud provider's API/CLI and console, using a credential scoped to read-only IAM permissions. No resources were created, modified, or deleted."]

1

1 Table of Contents

1 Table of Contents 1

2 Executive Summary 2
2.1 Overview . . . 2
2.2 Overall Risk Rating . . . 2
2.3 Findings by Severity . . . 2
2.4 Findings by Domain . . . 3

3 Scope & Methodology 4
3.1 Subject & Scope . . . 4
3.2 Benchmark / Framework Used . . . 4
3.3 Approach . . . 4
3.4 Severity Definitions . . . 4

4 Identity & Access Management 5
4.1 F-01 — [FILL: e.g. "IAM Role Trust Policy Allows Cross-Account Assumption from Any Account"] . . . 5

5 Network Security 6
5.1 F-02 — [FILL: e.g. "Database Security Group Permits Inbound Access from 0.0.0.0/0"] . . . 6

6 Data Protection 7
6.1 F-03 — [FILL: e.g. "Storage Bucket Publicly Readable and Listable"] . . . 7

7 Logging & Monitoring 8
7.1 F-04 — [FILL: e.g. "Audit Logging Disabled in Two of Five Regions"] . . . 8

8 Full Findings Catalogue 9

9 Recommendations 10

10 Appendix A — Tools Used 11

11 Appendix B — Full Resource Inventory Pointer 11

2 Executive Summary

Overview

A configuration security review was conducted against Example Corp — AWS Production Account (123456789012). [FILL: One sentence on the review method, e.g. "the review covered identity and access management, network exposure, data protection, and logging/monitoring configuration across all in-scope accounts."]

The assessment identified [FILL: N] **distinct findings**. [FILL: One or two sentences summarising the overall posture and the worst realistic outcome, e.g. "several S3 buckets are publicly readable and a number of IAM roles grant unscoped administrator access to CI/CD pipelines."]

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict].

Headline conclusions:

- [FILL: Headline finding 1]
- [FILL: Headline finding 2]
- [FILL: Headline finding 3]

Overall Risk Rating

CRITICAL

Findings by Severity

Severity	Count	Meaning
CRITICAL	[FILL: n]	[FILL: e.g. publicly exposed data store or unauthenticated admin access]
HIGH	[FILL: n]	[FILL: e.g. overly-broad IAM policy, unencrypted data store]
MEDIUM	[FILL: n]	[FILL: e.g. missing MFA enforcement, permissive security group]
LOW	[FILL: n]	[FILL: e.g. logging/retention gaps]

Findings by Domain

Domain	Count	Severities
Identity & Access Management	[FILL: n]	[FILL: n Critical, n High]
Network Security	[FILL: n]	[FILL: n High, n Medium]
Data Protection	[FILL: n]	[FILL: n Critical]
Logging & Monitoring	[FILL: n]	[FILL: n Medium, n Low]

3 Scope & Methodology

Subject & Scope

Item	Detail
Provider	[FILL: AWS / Azure / GCP]
Accounts/Projects	[FILL: list of account/subscription/project identifiers]
Access used	[FILL: Read-only role/service-account name]
Assessment type	Configuration review against the cloud provider's control plane (API/CLI/console); no in-guest access

Benchmark / Framework Used

[FILL: Name the baseline used, e.g. "CIS Amazon Web Services Foundations Benchmark v3.0" or "CIS Microsoft Azure Foundations Benchmark", plus any provider-specific Well-Architected / Security Hub findings folded in.]

Approach

1. **Inventory.** Enumerate all accounts/subscriptions/projects, regions, and resource types in scope.
2. **Automated baseline scan.** Run the chosen benchmark (via `Prowler`/`ScoutSuite`/ native tooling) to get a first-pass control-by-control result set.
3. **Manual verification.** Each automated finding is manually verified against the live configuration (false positives from stale benchmarks are common); manual review adds checks the benchmark does not cover (e.g. cross-account trust relationships).
4. **Risk contextualisation.** Findings are re-prioritised based on actual exposure (public reachability, data sensitivity, blast radius) rather than benchmark severity alone.

Severity Definitions

Level	Definition
CRITICAL	Public/unauthenticated exposure of sensitive data, or trivial full-account takeover.
HIGH	Overly-broad privilege grants, unencrypted sensitive data, exploitable misconfiguration.
MEDIUM	Missing hardening controls (MFA, key rotation) with a plausible attack path.
LOW / Info	Hygiene and best-practice gaps.

4 Identity & Access Management

[FILL: One paragraph summarising the IAM posture - root/owner account usage, MFA coverage, key-rotation practice, and the general shape of role/policy design (least-privilege vs. broad wildcard grants).]

Metric	Value	Notes
Users without MFA	[FILL: n / total]	[FILL: note]
Access keys older than 90 days	[FILL: n]	[FILL: note]
Roles/policies with wildcard (*:*) actions	[FILL: n]	[FILL: note]
Unused roles/service accounts (90+ days)	[FILL: n]	[FILL: note]

F-01 — [FILL: e.g. "IAM Role Trust Policy Allows Cross-Account Assumption from Any Account"]

Finding Metadata			
ID	F-01	**Severity**	CRITICAL
Resource	[FILL: role/policy ARN or resource ID]	**Category**	[FILL: IAM misconfiguration]

[FILL: Description, evidence (the offending policy JSON excerpt), impact, and remediation.]

5 Network Security

[FILL: One paragraph summarising network exposure - VPC/VNet layout, public subnets, and notable ingress rules.]

Metric	Value	Notes
Security groups allowing 0.0.0.0/0 on sensitive ports	[FILL: n]	[FILL: e.g. 22, 3389, 3306]
Publicly reachable databases	[FILL: n]	[FILL: note]
Load balancers without TLS enforced	[FILL: n]	[FILL: note]

F-02 — [FILL: e.g. "Database Security Group Permits Inbound Access from 0.0.0.0/0"]

Finding Metadata			
ID	F-02	**Severity**	HIGH
Resource	[FILL: security group / firewall rule ID]	**Category**	[FILL: Network exposure]

[FILL: Description, evidence, impact, and remediation.]

6 Data Protection

[FILL: One paragraph summarising storage/data posture - encryption at rest, public bucket/blob exposure, backup practices.]

Metric	Value	Notes
Storage buckets/containers publicly readable	[FILL: n]	[FILL: note]
Unencrypted data volumes/databases	[FILL: n]	[FILL: note]
Databases without automated backups	[FILL: n]	[FILL: note]

F-03 — [FILL: e.g. "Storage Bucket Publicly Readable and Listable"]

Finding Metadata			
ID	F-03	**Severity**	CRITICAL
Resource	[FILL: bucket/container name]	**Category**	[FILL: Data exposure]

[FILL: Description, evidence (do not include actual exposed data - describe categories only), impact, and remediation.]

7 Logging & Monitoring

[FILL: One paragraph summarising audit-logging coverage - e.g. CloudTrail/Activity Log/Cloud Audit Logs enabled account-wide, log retention, and whether alerting exists for sensitive events (root login, IAM policy changes, security-group changes).]

Control	Status
Account-wide audit logging enabled	[FILL: Yes / No / Partial]
Log integrity validation / immutability	[FILL: Yes / No]
Alerting on root/owner account usage	[FILL: Yes / No]
Alerting on IAM policy changes	[FILL: Yes / No]

F-04 — [FILL: e.g. "Audit Logging Disabled in Two of Five Regions"]

[FILL: Description, evidence, impact, and remediation.]

8 Full Findings Catalogue

ID	Title	Domain	Severity
F-01	[FILL: Title]	IAM	CRITICAL
F-02	[FILL: Title]	Network	HIGH
F-03	[FILL: Title]	Data Protection	CRITICAL
F-04	[FILL: Title]	Logging & Monitoring	MEDIUM

See the preceding domain sections for each finding's full detail (evidence, impact, remediation).

9 Recommendations

Priority	Recommendation
Immediate	[FILL: e.g. remove public read access from all storage buckets/containers holding sensitive data]
Short-term	[FILL: e.g. enforce MFA for all human IAM principals; rotate all access keys older than 90 days]
Long-term	[FILL: e.g. adopt infrastructure-as-code with policy-as-code (OPA/Sentinel) gating in CI]

10 Appendix A — Tools Used

- [FILL: e.g. Prowler, ScoutSuite, native CSPM console]

11 Appendix B — Full Resource Inventory Pointer

[FILL: Note where the full exported resource inventory (CSV/JSON) can be found, if produced separately from this narrative report.]